

TECH & AI 每日简报

2026 年 6 月 20 日 · 星期六

断供进入“今天”：Fable 5 退款大限到

300+ 安全大佬联署逼宫，Anthropic 一边在首尔重开战线、一边喊“几天内回来”

6/20

退款大限

300+

安全专家联署

85%

编程 Agent 被劫持率



断供进入兑现期：退款、身份验证与一场行业反水

- 6/20 是 Fable 5 / Mythos 5 付费用户的退款处理大限；Anthropic 同步搭建身份验证系统（约 7/8 上线），以便解禁后“仅向美国人”开放。
- 导火索首次还原：白宫先将投资方 SK Telecom 认定为“涉华风险”、要求收回 Mythos 5 访问，叠加 Amazon 上报 Fable 5 越狱漏洞，才升级成全面断供。
- 300+ 安全领袖在 freefable.org 联署，Stamos、Schneier、Tobac 在列；Nvidia、Adobe、Vercel 等表态支持恢复。
- Anthropic 不困守：首尔设第三个亚太办公室，签 MOU，拿下 NAVER、三星 SDS、LG CNS 等部署。

“

“我们很有信心，模型会在未来几天内重新可用。”

— Chris Ciauri，Anthropic 国际业务总监（首尔）

300+

安全专家联署反对

3 天

上线即被叫停模型寿命



本周 AI 安全三连

当大模型被“信任去读取”外部内容，攻击面不再是它会不会说错话，而是它被诱导去访问、去执行什么。



WARP

投毒“深度研究”搜索



Agentjacking

劫持 AI 编程代理



SearchLeak

一键搬空 M365 数据



13 个词就能把 AI 搜索带沟里：Cornell “WARP” 投毒攻击

- 在 Reddit 评论等普通 UGC 里插入短至约 13 个单词的“毒句”，即可操纵 ChatGPT Deep Research、Gemini 的检索与推理。
- 用户被悄悄导向虚假商家、诈骗链接，甚至根本不存在的产品。
- 命门在“食材”来源：这类代理抓取的网页约 17–23% 来自 Reddit、维基、Quora、YouTube 等人人可编辑的站点。
- 团队仅在沙盒中对 STORM、Co-STORM、OmniThink 三个开源代理做端到端验证，论文已挂 arXiv。

38–51%

单条毒评论的引导成功率

62%

多帖叠加成功率

17–23%

信源来自开放 UGC

信号 “深度研究”正被当作可信赖的二手大脑，用户很少回头核对来源。WARP 把 SEO 时代的“刷排名”升级成了“刷 AI 结论”——RAG 产品必须把信源可信度当成一等公民。



开发者 · AI 安全

一条假 Sentry 报错，就能劫持 Claude Code / Cursor / Codex

- “Agentjacking” 把恶意指令藏进看似正常的 Sentry 错误信息里；当编程代理读取报错、试图“帮你修 bug” 时，便把夹带的提示词当真实指令执行。
- 本质仍是间接提示注入，巧在选了一个开发者几乎不设防、却被代理默认信任去读取的入口——错误日志。
- FIRST 预测 2026 年全年披露 CVE 约 6.6 万个，是历史平均的两倍。

85%

主流代理利用成功率

2,388

已暴露的组织

结构性软肋

代理为“自动修 bug” 必须主动读取报错、日志、issue、依赖——而这些入口几乎都没被当作不可信输入处理。

信号 三连里最贴近开发者日常的一记：85% 成功率与 2,388 家暴露组织说明这不是理论威胁，而是企业把编程 Agent 接入 CI/CD 后必须立刻面对的现实风险。



点一下链接，邮箱日历就被搬空：M365 Copilot “SearchLeak”

- CVE-2026-42824：受害者只需点击一条精心构造的恶意 URL，Copilot 就会按指令去搜索并悄悄外泄数据。
- 可触及 Copilot 有权访问的邮箱、日历、OneDrive 与 SharePoint 内容。
- 微软在公开披露前、于 6 月初已服务端静默修复，用户无需任何操作；Varonis 称未见野外利用。

三步攻击链

- 1 参数→提示词注入**
恶意 URL 参数
- 2 HTML 渲染竞态**
race condition
- 3 Bing SSRF 绕过 CSP**
外泄数据

信号 提示注入从聊天框玩法升级为企业级数据外泄：当 Copilot 被授予整租户读取权限，它本身就是高价值“被动内鬼”——好在微软先修后曝，给了负责任披露一个正面样本。



Snap 把编程 Agent 戴上了脸：SPECS AR 眼镜内置 Claude Code

- 差异点在软件：把 Claude Code、Codex、Cursor 等编程 Agent，以及 OpenAI、Gemini API 直接接入眼镜。
- 硬件：双 Qualcomm Snapdragon、51° 视场角、47mm 镜框、整机约 132 克。
- Snap 还放出自家 Spatial Benchmark，称 GPT-5.5 在该空间能力基准上拿下头名。
- 2026 秋季于美、英、法上市。

\$2,195

售价（\$200 可退定金）

132 g

整机重量

叙事转向

从“拍照滤镜”转向“戴在脸上的 AI 终端”——让眼镜成为 AI Agent 的身体。



时隔六年再做音箱：Google 把 Gemini 装进 \$99 的 Home Speaker

- 自 2020 年以来第一款全新设计的智能音箱，原生围绕 Gemini for Home 打造。
- 主打自然多轮对话与直觉式智能家居控制：可像聊天一样连续追问、下复合指令。
- 底部呼吸灯环提示聆听 / 思考 / 回应；提供 Hazel、Porcelain、Jade、Berry 四色。
- 6/17 开启预订、6/25 发货。Amazon（Alexa Nova）、Apple（新 Siri HomePod）同场竞速。

\$99.99

起售价

6 年

距上款全新音箱

三厂同赌

大模型能否让音箱从“遥控器”变回“家庭助理”，是 Google、Amazon、Apple 同时在赌的一件事。

信号 把前沿大模型原生塞进 \$99 家用硬件，是把 Gemini 从手机 App 推向“全屋在场”的关键一步——谁让客厅那台一直在听的设备真正好用，谁就握住消费级 AI 最高频的入口之一。



把“和平队”搬进 AI : Anthropic 推 Claude Corps

- 面向早期职业阶段美国人的全国性奖学金 / 服务计划，结构上对标 Peace Corps（和平队）与 AmeriCorps。
- 招募并资助年轻人，把 Claude 带进社区组织、非营利与公共服务一线，去解决具体本地问题。
- 与近期动作一脉相承：从 Frontier Red Team 进华盛顿做安全演示，到密集政策发声。



时机耐人寻味

在被出口管制卡脖子、又被指模型有风险的当口，Anthropic 主动讲一个“AI 为公众服务”的故事——把“谁在受益于前沿 AI”的叙事从硅谷扩展到社区与普通美国人。



今日要点



断供进入兑现期

退款大限、身份验证系统、300+ 专家联署——“出口管制能不能管大模型”成了行业级合法性之争。



AI 安全三连同指一个结论

WARP、Agentjacking、SearchLeak 共证：风险不在模型说错话，而在它被信任去读取、被诱导去执行什么。



agentic 系统的入口都是攻击面

报错、日志、UGC、URL 参数——凡是代理默认信任去读取的内容，都必须当作不可信输入来防。



AI 终端形态之争升温

Snap 把编程 Agent 戴上脸、Google 把 Gemini 装进音箱——大模型正在争夺随身与全屋的高频入口。



Anthropic 双线作战

一边在首尔重开战线、拿企业部署，一边推 Claude Corps 讲“AI 为公众服务”的政策叙事。